Security Operations Lab: an offline fictional case study

Page 1 of 2 - Problem and design

Scope. This Codex-assisted security-operations exercise models a fictional fitness application using synthetic identities, documentation IP addresses and imaginary metadata counts. It does not access WHOOP systems, health records or real accounts. It is a portfolio lab, not production SOC work or AI research.

Problem. An analyst needs a queue that makes unusual sign-ins, protected-role assignments and exports reviewable without treating a rule match as proof of compromise. The lab must expose data-quality errors, preserve evidence and keep scenario answers away from detection.

Approach. A Python standard-library CLI validates JSONL, requires timezone-aware timestamps, normalizes them to UTC and sorts deterministically. Validation precedes deduplication; conflicting IDs are excluded and reported. Three rules cover failures followed by success, protected-role changes without matching policy approval, and export counts grouped by actor and resource. JSON alerts and CSV/Markdown queues preserve evidence, severity, confidence and limitations. Actor-only groups are triage aids, not causal proof.

Measured change. The baseline sign-in profile requires five failures. A versioned experimental profile requires four, preserving the inclusive windows and reset. The hypothesis was that this would catch some malicious four-failure sequences while increasing benign alerts. The author separated development and holdout sets and froze the profile and hashes before the first holdout run. The same author created the scenarios, so this is not an independently collected benchmark.

Source trail. The experiment plan, fixture manifest, frozen hashes, alerts and evaluations are in docs/strengthening_experiment.md, data/strengthening_fixture_manifest.json and reports/strengthening/.

Page 2 of 2 - Findings and limitations

Held-out findings. Across 12 self-authored scenarios, baseline generated four alerts with TP/FP/TN/FN of 2/2/5/3, precision 2/4 and recall 2/5. The four-failure profile generated seven alerts with counts 4/3/4/1, precision 4/7 and recall 4/5. The baseline matched 4/4 authored candidate/evidence expectations and the revision matched 7/7. Revised detection recovered two simulated malicious cases but added one benign alert; it did not merely lower priority. These small constructed results do not establish production accuracy.

Investigation decisions. An initial sign-in and role-assignment case remains historically indeterminate on its original logs. New fictional owner and change-review records support a simulated escalation; containment is proposed, not performed. Another initial sign-in case gains fictional confirmation and MFA/device evidence supporting a simulated benign closure. Scenario truth is not investigation evidence. The phishing walkthrough is a separate paper-only exercise.

Verification. A strict evaluator returns nonzero when candidate/evidence expectations fail, while ordinary report generation can complete despite mismatches. Meaningful tests cover rule boundaries, approval checks, partial input, strict evaluation and follow-up references. Tests and evidence checks are self-review, not independent review. Export approval usage depends on supplied events; overlapping windows may increase queue volume.

Limits and reproducibility. Follow the README for offline commands. Original fixtures, labels and reports remain preserved. No user contact, containment, real incident, production deployment or operational impact is claimed. Git has no committed revision; a fresh committed-checkout test and publication privacy review remain outstanding.

Evidence. reports/strengthening/summary.json; reports/strengthening/freeze.json; docs/investigations/; data/investigations/followup_evidence_v1.json; tests/.